

Table: NIST CSF and NIST RMF Controls and Clauses

Framework	Category/Function	Control/Clause	Description
NIST CSF	Identify (ID)	Asset Management (ID.AM)	Identify assets, devices, data, and personnel to manage cybersecurity risks.
		Business Environment (ID.BE)	Organizational roles and responsibilities are defined and communicated.
		Governance (ID.GV)	Organizational policies and governance are established for cybersecurity.
		Risk Assessment (ID.RA)	Risk assessments are conducted regularly.
		Risk Management Strategy (ID.RM)	Organization's priorities, constraints, and risk tolerances are established and informed decisions are made.
	Protect (PR)	Identity Management, Authentication, and Access Control (PR.AC)	Control access to assets and associated facilities.
		Awareness and Training (PR.AT)	Ensure that personnel are trained and aware of cybersecurity responsibilities.
		Data Security (PR.DS)	Data is managed consistent with the organization's risk strategy.
		Information Protection Processes and Procedures (PR.IP)	Implement policies and procedures for cybersecurity protection.
		Maintenance (PR.MA)	Maintenance and repairs are performed on assets.
NIST RMF	Detect (DE)	Anomalies and Events (DE.AE)	Detect anomalous activity and potential cybersecurity events.
		Security Continuous Monitoring (DE.CM)	Continuously monitor systems for cybersecurity incidents.
	Respond (RS)	Response Planning (RS.RP)	Develop and implement incident response plans.
		Mitigation (RS.MI)	Contain and mitigate cybersecurity incidents.
	Recover (RC)	Recovery Planning (RC.RP)	Develop and implement strategies to recover from cybersecurity incidents.
		Organizational Preparation	Establish the context for risk management through policies,

Framework	Category/Function	Control/Clause	Description
			governance, and key roles.
	Categorize (Step 2)	Categorize Information System (FIPS 199/SP 800-60)	Categorize the information system and its information based on impact levels (Low, Moderate, High).
	Select (Step 3)	Select Security Controls (SP 800-53)	Select appropriate security controls based on the categorized system.
	Implement (Step 4)	Implement Security Controls (SP 800-53)	Implement the selected security controls within the information system.
	Assess (Step 5)	Assess Security Controls (SP 800-53A)	Assess the effectiveness of the implemented security controls.
	Authorize (Step 6)	Risk-Based Decision (SP 800-37)	Authorize the information system operation based on risk assessment and acceptance.
	Monitor (Step 7)	Continuous Monitoring (SP 800-137)	Continuously monitor security controls and their effectiveness over time.
	Control Families	Access Control (AC)	Controls focused on limiting access to authorized users and devices.
		Awareness and Training (AT)	Ensure personnel are properly trained in security responsibilities.
		Audit and Accountability (AU)	Enable auditing of information systems and monitor activities.
		Risk Assessment (RA)	Identify and assess risks to the organization's information systems.
		System and Communications Protection (SC)	Protect the integrity, availability, and confidentiality of information transmitted across networks.

Here's a detailed mapping table showing how ISO/IEC 27001 clauses and controls align with the NIST Cybersecurity Framework (CSF) and NIST Risk Management Framework (RMF). This mapping can help organizations comply with multiple standards by understanding the similarities and gaps between ISO 27001, NIST CSF, and NIST RMF.

Table: ISO 27001 Mapping to NIST CSF and NIST RMF

ISO/IEC 27001 Clause/Control	NIST CSF Category	NIST RMF Control Family (SP 800-53)
------------------------------	-------------------	-------------------------------------

ISO/IEC 27001 Clause/Control	NIST CSF Category	NIST RMF Control Family (SP 800-53)
Clause 4: Context of the Organization	Identify (ID) - Governance (ID.GV), Risk Management (ID.RM)	Organizational Preparation, Risk Assessment (RA)
Clause 5: Leadership	Identify (ID) - Governance (ID.GV)	Organizational Preparation, Security Planning (PL)
Clause 6: Planning	Identify (ID) - Risk Assessment (ID.RA), Risk Management Strategy (ID.RM)	Risk Assessment (RA), Planning (PL)
Clause 7: Support	Protect (PR) - Awareness and Training (PR.AT)	Awareness and Training (AT)
Clause 8: Operation	Protect (PR) - Information Protection Processes and Procedures (PR.IP)	Security Assessment and Authorization (CA), Security Control Implementation (SI)
Clause 9: Performance Evaluation	Respond (RS) - Response Planning (RS.RP), Improvement (RS.IM)	Risk Monitoring (RM), Performance Measurement (PM)
Clause 10: Improvement	Recover (RC) - Recovery Planning (RC.RP)	Risk Monitoring (RM), Incident Response (IR)
A.5 Information Security Policies	Identify (ID) - Governance (ID.GV)	Policies and Procedures (PL)
A.6 Organization of Information Security	Identify (ID) - Governance (ID.GV)	Access Control (AC), Security Roles and Responsibilities (SR)
A.7 Human Resource Security	Protect (PR) - Awareness and Training (PR.AT)	Awareness and Training (AT), Personnel Security (PS)
A.8 Asset Management	Identify (ID) - Asset Management (ID.AM)	Asset Management (CM), System and Information Integrity (SI)
A.9 Access Control	Protect (PR) - Identity Management and Access Control (PR.AC)	Access Control (AC)
A.10 Cryptography	Protect (PR) - Data Security (PR.DS)	System and Communications Protection (SC)
A.11 Physical and Environmental Security	Protect (PR) - Physical Security	Physical and Environmental Protection (PE)
A.12 Operations Security	Protect (PR) - Information Protection Processes and Procedures (PR.IP), Security Continuous Monitoring (DE.CM)	Security and Monitoring (SI), Audit and Accountability (AU)
A.13 Communications Security	Protect (PR) - Data Security (PR.DS)	System and Communications Protection (SC)

ISO/IEC 27001 Clause/Control	NIST CSF Category	NIST RMF Control Family (SP 800-53)
A.14 System Acquisition, Development and Maintenance	Protect (PR) - Information Protection Processes and Procedures (PR.IP)	System and Services Acquisition (SA), Configuration Management (CM)
A.15 Supplier Relationships	Identify (ID) - Supply Chain Risk Management (ID.SC)	Security Assessment and Authorization (SA), System and Services Acquisition (SA)
A.16 Information Security Incident Management	Respond (RS) - Incident Response (RS.RP)	Incident Response (IR)
A.17 Information Security Aspects of Business Continuity Management	Recover (RC) - Recovery Planning (RC.RP)	Contingency Planning (CP), Incident Response (IR)
A.18 Compliance	Identify (ID) - Governance (ID.GV), Risk Assessment (ID.RA)	Security Control Assessment (CA), Risk Assessment (RA)

Key Mapping Considerations:

1. **ISO/IEC 27001:** Focuses on establishing, implementing, maintaining, and continually improving an information security management system (ISMS).
2. **NIST CSF:** Provides a framework of core cybersecurity activities organized into functions (Identify, Protect, Detect, Respond, Recover) to enhance security resilience.
3. **NIST RMF:** Provides a structured process that integrates security, privacy, and risk management activities into the system development lifecycle, aligning controls from NIST SP 800-53.

Explanation of Controls:

- **Identify (ID)** in NIST CSF is similar to the planning and leadership clauses in ISO 27001.
- **Protect (PR)** overlaps significantly in areas such as access control, encryption, and awareness training.
- **Detect (DE)** relates to operations monitoring and anomaly detection, while ISO 27001's focus on operations security aligns here.
- **Respond (RS)** and **Recover (RC)** have similar incident response and business continuity management clauses between ISO 27001 and NIST CSF/RMF.